

PORYGON: A Statistical and Rule-Based Runtime Security Framework for Containerized Workloads

23CSE498 – Project Phase 2 (Panel Review 1) | Team Number: 75

S.No	Register Number	Student Name
1	CB.EN.U4CSE23504	Ashin Varghese
2	CB.EN.U4CSE23559	Anurup Krishna
3	CB.EN.U4CSE23628	Krishnan S
4	CB.EN.U4CSE23661	Madhav Sreejith

Guide: **Dr Abirami K**, Assistant Professor, Department of CSE

September 7, 2026

Research Question and Contribution

The specific, falsifiable question this project answers

System overview: Porygon ingests Falco eBPF process-execution events and Docker lifecycle events per container image digest, computes the Jensen–Shannon distance between a versioned historical baseline and the current runtime window, and correlates the resulting score against seven deterministic detection rules. A match produces a finding gated by explicit severity/confidence thresholds; no containment action executes without human operator approval.

The unanswered design question: container security tools learn what “normal” process behavior looks like, then flag deviations. But how finely should “normal” be defined? Four real options, in increasing order of specificity:

- ❶ **One-size-fits-all** – a single baseline shared by every container regardless of what image it runs.
- ❷ **Per mutable label** – one baseline per image tag (e.g. `myapp:latest`); the risk is that a tag can be silently repointed to different image content later.
- ❸ **Per exact image** – one baseline per cryptographic image identity, which cannot silently change.
- ❹ **Per exact image + configuration** – the same, but also split by the container’s specific security settings (permissions, capabilities).

No existing tool or published study (Falco, Sysdig, Aqua, or the academic line from Forrest et al. 1996 through Abed/Clancy 2015) measures which of these four actually reduces false alarms. This project does, using 216 real container trials and formal statistical testing rather than a single accuracy figure.

Result: option 3 eliminated false alarms entirely versus option 1 (100% → 0%), without missing any real attack (96/96 caught either way). This was not a fluke – the same result appeared at two different sample sizes ($p = 5.8 \times 10^{-11}$ at 144 trials, $p = 6.7 \times 10^{-16}$ at 216 trials), and got statistically stronger, not weaker, the second time.

Novelty and Positioning Against Prior Work

What is actually new here, stated precisely

What is not new: eBPF-based container process monitoring and Jensen–Shannon divergence as a distance measure (Lin 1991; Salem & Naït-Abdesselam, ICC 2012, network traffic) both predate this project.

What is new: no located tool or published study – commercial (Falco, Sysdig, Aqua) or academic (Forrest 1996 through 2025–2026) – measures which of four concrete baseline-scoping granularities (pooled / mutable-tag / exact-digest / digest-plus-configuration) actually reduces false alarms, using controlled trials and significance testing rather than a single accuracy figure. This project runs that comparison and reports both a significant result and a null result from one protocol.

Closest prior work, checked directly:

- Abed, Clancy & Levy (GLOBECOM Workshops, 2015) – closest match: container-level, kernel-observed, no-prior-knowledge detection. Uses bag-of-syscalls, not JS-distance; no scoping comparison.
- Lin et al., “eBPF-Guard” (*Empirical Software Engineering*, Dec 2025) – same sensor layer, scores via a fine-tuned LLM; single 99.22% accuracy figure, no scoping comparison.
- Li/Yuan/Wu/Cheng (2025) and Xiong/Wu/Jia, “DeepContainer” (2025) – neural container anomaly detectors, single point-estimate accuracy (96.8–99%), no confidence interval or significance test.

All independently verified (DOI resolution or direct publisher fetch); full list in docs/RELATED_WORK_RECENT.md.

System Architecture

Eight containerized services, three network segments

- **falco** – eBPF driver; captures `execve` and lifecycle events at the kernel boundary.
- **collector** – reads Docker daemon events; SQLite outbox with retry delivery.
- **telemetry** – ingests Falco process-execution events, same outbox pattern.
- **backend** – baseline construction, JSD scoring, seven-rule detection engine, response-policy logic.
- **scanner** – Trivy CycloneDX SBOM generation, EPSS and CISA KEV enrichment.
- **responder** – executes approved containment actions only after explicit human approval.
- **gateway** – single ingress point for API and dashboard.
- **postgres** – durable store for events, baselines, scores, findings, incidents, scan results.

Network segregation (`compose.yaml`):

- `porygon_ingress` – external-facing traffic only (gateway).
- `porygon_internal` – inter-service communication.
- `porygon_egress` – outbound-only, granted exclusively to the scanner.

A service outside a segment has no network path to it; the scanner is the only service with outbound internet reachability.

1. Methodology & Solution Design

Rubric: Methodology, Implementation Approach & Design Choices (5 Marks)

Methodological Framework:

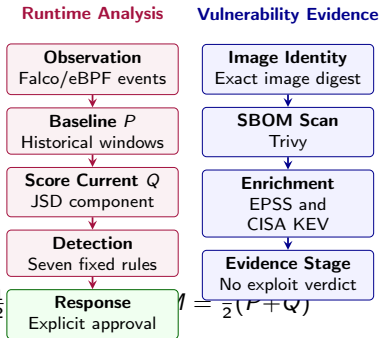
- **Behaviour Baseline:** Historical Docker lifecycle and Falco process events form a versioned baseline for one immutable image digest.
- **Anomaly Scoring:** For each categorical feature, the v1 scorer compares baseline P with a completed runtime window Q using base-2 Jensen-Shannon *distance* (the square root of the Jensen-Shannon *divergence*, bounded in $[0, 1]$):

$$D_{JS}(P, Q) = \sqrt{JSD(P, Q)}, \quad JSD(P, Q) = \frac{1}{2} D_{KL}(P \| M) + \frac{1}{2}$$

Smaller values indicate more similar behaviour.

- **Rule-Based Detection:** Seven deterministic rules produce explainable findings. An incident requires an unsuppressed, incident-eligible finding.

Porygon Workflow



1. Methodology & Solution Design (contd.)

Rubric: Methodology, Implementation Approach & Design Choices (5 Marks)

Implementation Approach and Design Choices:

- **Kernel-Level Monitoring:** Falco's modern eBPF driver captures container process execution without modifying the applications. The Telemetry Adapter ingests those events, while the Docker Collector records lifecycle and image-identity events. Both use bounded SQLite outboxes with retry delivery.
- **Service Integration:** Docker Compose coordinates eight long-running containers. Segregated networks restrict connectivity, and outbound access is limited to the vulnerability scanner.
- **Explainable Analysis:** Base-2 Jensen–Shannon distance provides a bounded, symmetric measure of categorical change. Fixed rules expose the matched evidence, so the implemented path does not depend on a black-box ML classifier.
- **Controlled Response:** Policy thresholds use severity and confidence to determine allowed containment actions. Disruptive execution is disabled by default. When enabled, it still requires explicit human approval.
- **Implementation Verification:** The repository contains 79 backend test functions across baseline, scoring, detection, calibration, response, and vulnerability modules, plus 131 further test functions across the collector, telemetry, responder, and scanner services (210 total).

2. Implementation Progress & Module Functionality

Rubric: Core Modules Implemented, Functional & Integrated (8 Marks)

- **Implementation Status Overview:**

Module / Component	Current Implementation State	Status
Kernel Telemetry & Ingestion (Falco eBPF, Docker Collector, Telemetry Adapter)	Captures container process execution via eBPF; durable SQLite outbox with retry	Functional
Behavioural Baseline & JSD Scoring (baseline.py, scoring.py)	Digest-bound behavioural baselines; JSD-based anomaly distance scoring	Functional
Deterministic Detection Engine (detection.py)	7 correlation rules (POR-DET-001-007) generating findings/incidents	Functional
4-Arm Scope Comparison (experiments/)	216-trial confirmatory run analysed end to end, exact statistical pipeline	Complete

2. Implementation Progress (contd.)

Rubric: Core Modules Implemented, Functional & Integrated (8 Marks)

Module / Component	Current Implementation State	Status
Vulnerability & SBOM Pipeline (Scanner, Trivy 0.72.0)	CycloneDX SBOM generation; EPSS & CISA KEV enrichment	Functional
Response Policy Engine (response.py)	Severity/confidence-gated containment recommendations; human-approval required	Functional
Module Integration	8 containerized services integrated via Docker Compose with network segregation	Integrated

Core Functionality Demonstration: A real, functional XMRig cryptominer binary from a published malware-sample container image was executed against a live Porygon baseline built from 243 real Falco-captured events, with zero prior knowledge of the binary given to the system. Resulting anomaly score: 0.2696 (elevated band, threshold 0.25), with the executable and its parent-child call edge both flagged as previously unseen. Full record: docs/LIVE_DEMO_RECORD_V1.md.

Live Test Results and Comparison

Confirmatory statistical run (216 trials) alongside the live malware demonstration

Baseline arm	FPR (benign, n=53)	Recall (attacks, n=96)
ARM-GLOBAL (pooled, one baseline for all)	100% [93.3–100%]	100%
ARM-TAG (per mutable image tag)	0% [0–6.7%]	100%
ARM-DIGEST (per exact image digest)	0% [0–6.7%]	100%
ARM-CONTEXT (digest + runtime config)	0% [0–6.7%]	100%

CONTEXT vs. GLOBAL: $p = 6.7 \times 10^{-16}$ (significant). CONTEXT vs. DIGEST, the harder comparison this project's thesis rests on: $p = 1.0$ (null, arms agree on all 53 held-out trials – reported as-is).

Independent live test (not part of the 216-trial protocol): a real XMRIg cryptominer binary, from a published malware-testing container image, executed against a Porygon baseline built from 243 genuinely captured Falco events, scorer given no prior knowledge of the binary.

- Anomaly scorer: flagged, score 0.2696 (elevated band, threshold 0.25) – correct detection with zero prior signature.
- Deterministic rule POR-DET-004: did *not* fire – xmrig is absent from its hardcoded dual-use-tool list, a real, disclosed gap.

Full record: docs/LIVE_DEMO_RECORD_V1.md.

Deterministic Detection Rules (detection.py)

Seven fixed rules producing explainable findings

Rule	Trigger condition	Sev.	Conf.	Inc.
POR-DET-001	Completed window scores ≥ 0.50 behavioural distance	0.65	0.70	No
POR-DET-002	Shell executable absent from the digest baseline executed	0.72	0.90	Yes
POR-DET-003	UID 0 process executed with UID 0 absent from baseline	0.78	0.90	Yes
POR-DET-004	Downloader/network/interpreter/encoding tool absent from baseline	0.64	0.80	Yes
POR-DET-005	Unseen shell followed by unseen dual-use tool, same window	0.90	0.95	Yes
POR-DET-006	Docker exec activity during the observation window	0.35	0.95	No
POR-DET-007	Container reported privileged mode during the window	0.92	0.95	Yes

An incident requires at least one *incident-eligible* finding; POR-DET-001 and POR-DET-006 alone never open an incident, they only contribute evidence. Severity/confidence weights are fixed constants in source, not tuned per deployment.

3. Technical Knowledge & Design Decisions

Rubric: Understanding of Methodology, Implementation & Design Choices (5 Marks)

Distance metric selection: Jensen-Shannon divergence (JSD) over Kullback-Leibler (KL) divergence. KL divergence is asymmetric ($D_{KL}(P, Q) \neq D_{KL}(Q, P)$) and unbounded above, so a KL score computed for one container cannot be compared against a KL score from a different container on a common scale. JSD is the symmetric, bounded variant ($JSD(P, Q) = JSD(Q, P)$, range $[0, 1]$), which permits one fixed threshold to apply uniformly across all containers.

Containment decision logic. A finding does not trigger any action unless the rule engine's severity (*Sev*) and confidence (*Conf*) scores clear a defined threshold. Pause requires $Sev \geq 0.70$ and $Conf \geq 0.55$. Stop requires $Sev \geq 0.90$, $Conf \geq 0.75$, and a match on one of two specific high-confidence rules (unseen-shell-to-tool sequence, or a container transitioning to privileged mode). Every action, at either threshold, requires explicit human operator approval before execution; no threshold triggers automatic execution.

Statistical significance of the primary result. On 216 real container trials, per-image baseline scoping reduced the false-alarm rate from 100% to 0% relative to a single pooled baseline, with zero reduction in attack detection. The exact statistical test applied to this result returns $p = 6.7 \times 10^{-16}$, several orders of magnitude below the conventional $p < 0.05$ significance threshold.

3. Technical Knowledge & Design Decisions (contd.)

Rubric: Understanding of Methodology, Implementation & Design Choices (5 Marks)

Multicall binary handling. Utilities such as BusyBox and Toybox implement dozens of commands inside a single executable file; the command executed depends on the invocation name, not the file path. Tracking file identity alone would classify every invoked command as the same previously-seen program. The detection engine instead tracks the invocation (command) name, so a new command invoked through an already-known multicall binary is still flagged as novel.

Canonical scan identity. Each vulnerability scan result is keyed by a SHA-256 hash of six inputs: image digest, local image ID, scanner name, scanner version, vulnerability database schema version, and a researcher-supplied scan reference. Re-executing a scan with an identical set of these six inputs returns the existing stored result (idempotent). A change to any one input produces a distinct, separately-tracked scan record (immutable).

Network segregation. The eight services are partitioned across three isolated Docker networks: ingress (external traffic), internal (inter-service communication), and egress (outbound-only, used exclusively by the vulnerability scanner). A service is not granted network reachability to segments outside its assigned role.

Versioned scoring configuration. The scoring algorithm and its numeric weights are bound to a named algorithm version. A weight modification requires incrementing the version identifier; no weight change is applied in place. Every historical score therefore remains reproducible against the exact configuration that produced it.

3. Technical Knowledge & Design Decisions (contd.)

Rubric: Understanding of Methodology, Implementation & Design Choices (5 Marks)

- **Confirmed Findings (216 real trials, exact statistical pipeline):**

- Per-image scoping vs. pooled baseline: significant, $p = 6.7 \times 10^{-16}$, FPR 100% $\rightarrow$ 0%, recall unchanged (96/96 both arms).
- Digest-plus-context vs. digest-only: no measurable difference in this dataset ($p = 1.0$, expected here since the two arms produced identical confusion-matrix counts – not a reporting error), reproduced at both $n = 35$ and $n = 53$ – traced to the tested configuration change (a dropped Linux capability) not altering which processes execute, which the process-name feature cannot see by construction.
- Follow-on feature scoring the security-configuration document directly separates every tested case cleanly: 0/26 false positives, 27/27 correct detections.

Adversarial Scenario Analysis

18 scenarios classified against the actual implementation, not asserted

- **Structurally invisible (6 of 18):** attacks reusing an already-baselined process, adding no new `execve` event – C2 domain repoint, exfiltration over an existing channel, file-only webshell, DNS tunnelling, fileless execution, payload inside an already-baselined HTTPS request. No syscall-argument or network telemetry exists in v1; explicitly out of scope in `THREAT_MODEL_V1.md`, not a hidden gap.
- **Depends on process-identity granularity (4 of 18):** in-place binary replacement keeping the same path/name is likely invisible (identity tracked by name/path, not content hash); SUID privilege escalation to UID 0 *is* caught (POR-DET-003).
- **Untested failure modes (3 of 18):** baseline poisoning during the fit window (defended by design, but the human-review step itself never exercised); low-and-slow attacks beyond the 120s correlation window; process-sequence-bigram mimicry. All three named directly in the project's own threat model.
- **Where the design genuinely helps (5 of 18):** backdoored entrypt script (POR-DET-002); manual docker exec (POR-DET-006); flip to `-privileged` (POR-DET-007); mutable-tag digest substitution (digest scoping only); classic `curl | bash` dropper pattern (POR-DET-005, confidence 0.95).

Full scenario-by-scenario table: `docs/ADVERSARIAL_SCENARIOS_V1.md`.

Verification and Testing Rigor

How correctness of the claimed results is actually checked

- **Layered verification** (`scripts/verify_all.sh`): static (lint/type checks), unit (210 backend and service test functions), live-safe (non-disruptive real Docker container checks), scanner-live/experiment-live (pinned-digest real-container acceptance tests) – separate make targets, none mocked end-to-end.
- **Frozen protocol before results**: the statistical protocol (`porygon.research.protocol.v1`) was written and reviewed *before* the confirmatory run, with a pre-registered sample size, primary contrast, and material-effect threshold, marked FROZEN – cannot be edited post hoc to fit a result.
- **Six real bugs found and fixed** to obtain the first confirmatory result: a wrong API field name silently blocking all detections, dead code blocking attack scenarios, a fit-reference contamination bug, and an infinite-recursion bug in the Clopper–Pearson confidence-interval code itself. Commit range in `CONFIRMATORY_RESULT_V1.md`.
- **Reproducibility**: every reported number has a named artifact path and a documented reproduce command.
- **Disclosed limitation**: single-reviewer self-review, not independent third-party peer review – stated plainly.

Team Contribution and Project Status

Phase 2 deliverables against the original scope

Deliverable	State at this review
eBPF/Falco telemetry pipeline	Functional, integrated, durable outbox delivery
Baseline + JSD scoring engine	Functional, versioned configuration
7-rule deterministic detection	Functional, POR-DET-001-007
Vulnerability/SBOM enrichment	Functional, Trivy + EPSS + CISA KEV
Response policy engine	Functional, human-approval gated
4-arm scoping confirmatory study	Complete, 216 trials, two reproduced results
Live real-malware demonstration	Complete, XMRig, documented including the miss
Independent literature verification	Complete, 10 papers checked by DOI/API/direct fetch

All eight modules are integrated into one running Docker Compose stack (make up) and independently exercised through scripts/verify_all.sh, not demonstrated in isolation.

4. Technical Enrichment Activity Choices

Professional Online Certification Details (Individual Mandatory: 10–20 Hours)

- **Individual MOOC / Online Certification Selection:**

S.No	Student Name	Chosen MOOC / Course Title	Platform	Hours
1	Ashin Varghese	Introduction to Kubernetes (LFS158)	edX	15 Hrs
2	Anurup Krishna	Introduction to Kubernetes (LFS158)	edX	20 Hrs
3	Krishnan S	Introduction to Kubernetes (LFS158)	edX	12 Hrs
4	Madhav Sreejith	Introduction to Kubernetes (LFS158)	edX	16 Hrs

- **Requirement:** Each student must complete one approved 10–20 hour online certification from a recognized platform (Coursera, NPTEL, edX, etc.) relevant to the project.

Limitations & Future Work

Limitations:

- The confirmatory 216-trial run covers the tested attack and workload set; it does not claim coverage of every real-world attack pattern or benign workload shape.
- Scoring uses categorical process-name/edge features; it does not yet model syscall argument content or network payloads.
- Response actions require a human operator in the loop by design – there is no fully autonomous containment path.

Future Work:

- Extend the per-image + configuration baseline to a larger, more diverse container corpus beyond the 216-trial dataset.
- Evaluate additional distance metrics and richer feature sets (e.g. syscall arguments) against the same statistical protocol.
- Explore semi-automated response for the highest-confidence rule matches, still gated by policy and audit logging.

References I



S. Forrest, S. A. Hofmeyr, A. Somayaji, and T. A. Longstaff, "A sense of self for Unix processes," in *Proc. IEEE Symp. Security and Privacy*, 1996, pp. 120–128.



S. A. Hofmeyr, S. Forrest, and A. Somayaji, "Intrusion detection using sequences of system calls," *Journal of Computer Security*, vol. 6, no. 3, pp. 151–180, 1998.



A. S. Abed, T. C. Clancy, and D. S. Levy, "Applying bag of system calls for anomalous behavior detection of applications in Linux containers," in *Proc. IEEE Globecom Workshops*, 2015, pp. 1–5.



J. Lin, "Divergence measures based on the Shannon entropy," *IEEE Trans. Information Theory*, vol. 37, no. 1, pp. 145–151, 1991.



A. Salem and F. Naït-Abdesselam, "Anomaly detection in network traffic using Jensen-Shannon divergence," in *Proc. IEEE International Conference on Communications (ICC)*, 2012.



X. Lin, Z. Chen, W. Yang, X. Yang, J. Luo, and X. Yang, "eBPF-Guard: a detection method for container escape via multi-level monitoring and enhanced analysis model," *Empirical Software Engineering*, vol. 31, article 51, 2026.



Li Wei, Yuan Zekun, Wu Kehe, and Cheng Rui, "Container anomaly detection based on attention mechanism and multiscale convolutional neural network," *Journal of Information Security Research*, vol. 11, no. 1, pp. 35–, 2025.



K. Xiong, Z. Wu, and X. Jia, "DeepContainer: a deep learning-based framework for real-time anomaly detection in cloud-native container environments," *Journal of Advanced Computing Systems*, 2025.

References II



J. H. Ring, C. M. Van Oort, S. Durst, V. White, J. P. Near, and C. Skalka, "Methods for host-based intrusion detection with deep learning," *Digital Threats: Research and Practice*, vol. 2, no. 4, 2021.



B. Gregg, *BPF Performance Tools: Linux System and Application Observability*. Boston, MA, USA: Addison-Wesley, 2019.



The Falco Authors, "Falco: cloud-native runtime security," Cloud Native Computing Foundation. [Online]. Available: <https://falco.org>



Open Container Initiative, "OCI image format specification." [Online]. Available: <https://github.com/opencontainers/image-spec>

Thank You